

IZVEŠTAJ: PREGLED I OČVRŠĆAVANJE (HARDENING) LINUX SISTEMA

Ovaj izveštaj predstavlja detaljan pregled bezbednosnih provera sprovedenih na Linux sistemu korišćenjem *Living off the Land* (LOTL) pristupa. Podeljen je u tri ključne celine koje pokrivaju korisnike, fajl sistem, servise i mrežnu infrastrukturu.

1. Pregled operativnog sistema, korisnika i privilegija

Ova sekcija se bavi analizom osnovnih komponenti sistema i kontrolom pristupa korisnika.

- **Verzija kernela:** Provera verzije kernela pomaže u identifikaciji da li postoje objavljene ranjivosti za tu specifičnu verziju operativnog sistema, odnosno da li sistem treba da se ažurira.
- **Root privilegije (UID 0):** Česta pogrešna konfiguracija ili namerni backdoor u `/etc/passwd` fajlu jeste dodeljivanje UID-a 0 nekom drugom korisniku. Na sistemu samo pravi root nalog sme da ima UID 0, jer bilo koji drugi korisnik sa ovim brojem automatski dobija kompletna administratorska prava nad celim sistemom.
- **Prazne lozinke:** Uočava naloge koji su ostali nezaštićeni u `/etc/shadow` fajlu. Ovakvi nalozi bi omogućili bilo kome da se uloguje bez ikakve autentifikacije.
- **Sudo grupa:** Omogućava brzi pregled svih običnih korisnika koji imaju pravo da eskaliraju svoje privilegije i izvršavaju komande kao administratori.
- **Korisnici sa interaktivnim shell-om:** Na svakom Linux sistemu postoji gomila sistemskih naloga koji služe isključivo za pokretanje servisa (poput `www-data` ili `mysql`). Bezbednosno pravilo je da ovi nalozi ne smeju imati mogućnost prijavljivanja na sistem. Ako napadač preuzme kontrolu nad servisom, a taj servis ima otvoren shell, napadač može direktno da kuca komande. Ova provera filtrira `/etc/passwd` i lista samo one korisnike koji zapravo mogu da se uloguju u terminal.
- **Korisnici u adm grupi:** Ova grupa omogućava korisnicima da čitaju sistemske logove u `/var/log` direktorijumu bez korišćenja `sudo` komande. Logovi često sadrže osetljive informacije o radu sistema, greškama aplikacija ili čak tragovima pokušaja napada, pa je bitno znati ko sve ima uvid u njih.

2. Pregled fajl sistema i servisa

Ova sekcija obrađuje bezbednost samog fajl sistema, prava pristupa i izloženost mrežnih servisa.

- **Fstab opcije montiranja:** Proveravaju se kritične opcije za particije poput `/tmp` i `/home`. Korišćenje opcije `noexec` sprečava izvršavanje binarnih fajlova, dok `nosuid` sprečava `setuid` interpretaciju. Opciju `noatime` ne treba koristiti jer briše informacije o pristupu fajlovima.
- **Dozvole na osetljivim fajlovima:** Fajlovi sa lozinkama i privatnim ključevima ne smeju biti čitljivi svim korisnicima. Neophodno je proveriti dozvole nad fajlovima kao

što su `/etc/shadow`, MySQL konfiguracija, SSH ključevi i eventualni backup-ovi `shadow` fajla.

- **SUID/SGID binarni fajlovi:** SUID fajlovi se izvršavaju sa privilegijama vlasnika i svaki SUID root fajl predstavlja potencijalni vektor eskalacije privilegija. Ovu listu treba ručno proveriti tražeći nestandardne fajlove.
- **Fajlovi zapisivi svim korisnicima (world-writable):** Fajlovi koje može menjati bilo koji korisnik su veliki rizik. Napadač može modifikovati konfiguracione fajlove, skripte ili web sadržaj da bi proširio pristup.
- **Backup direktorijumi:** Backup fajlovi često sadrže osetljive podatke poput senki lozinki, konfiguracija i baza. Ako su čitljivi svima, napadač lako može doći do kompromitujućih podataka.
- **Pokrenuti servisi:** Identifikuju se svi aktivni servisi, jer svaki nepotreban servis povećava površinu napada i treba ga onemogućiti.
- **SSH konfiguracija:** S obzirom na to da je SSH najčešći vektor napada, proverava se zabrana direktnog root logina, isključenost SSHv1 protokola, zabrana TCP *forwarding*-a i korišćenje nestandardnog porta.
- **MySQL konfiguracija:** Baza podataka ne sme biti dostupna sa spoljnih interfejsa, pa se proverava `bind-address` parametar i prisustvo korisnika bez lozinke.
- **Crontab skripte:** Skripte koje izvršava root cron moraju biti zapisive isključivo od strane root korisnika. U suprotnom, bilo koji korisnik može ubaciti maliciozan kod koji će se izvršiti sa maksimalnim privilegijama.

3. Pregled mrežnih konfiguracija, vremena i logovanja

Ovaj segment je fokusiran na mrežnu izloženost, sinhronizaciju vremena, upravljanje logovima i analizu softverskih paketa.

- **OS, Kernel i Uptime:** Identifikacija stanja operativnog sistema i kernela detektuje potencijalno prisustvo ranjivih komponenti. Provera sistemskog `uptime` indikatora direktno ukazuje na to kada je sistem poslednji put restartovan, što je često neophodno nakon instalacije kritičnih bezbednosnih zavrta za kernel.
- **Mreža i usmeravanje (IP, Rute, DNS):** Pregledom mrežnih interfejsa i usmeravanja utvrđuje se površina mrežne izloženosti. Analizom fajlova `/etc/resolv.conf` i `/etc/hosts` proverava se validnost DNS konfiguracije kako bi se sprečila maliciozna preusmeravanja mrežnog saobraćaja.
- **Zaštitni zid (iptables / ip6tables):** Proverava se kompletna lista pravila za filtriranje saobraćaja. Pored restrikcija za dolazni saobraćaj, odlazni saobraćaj (egress) takođe mora biti strogo ograničen; ovo drastično otežava eksfiltraciju podataka i usporava napadača ukoliko dođe do kompromitacije. Ista pravila moraju biti primenjena i na IPv4 i na IPv6 steku.
- **Sinhronizacija vremena (NTP):** Strogo tačna sinhronizacija sa NTP serverom je apsolutno neophodna za korelisanje bezbednosnih događaja. Bez tačnog vremena, analiza logova nakon incidenta je otežana, a validacija SSL sertifikata i vremenskih tokena može biti kompromitovana.
- **Udaljeno logovanje (rsyslog):** Centralizovano logovanje je kritično. Konfiguracija servera mora podržavati slanje sistemskih dnevnika na udaljeni `syslog` server (npr.

preko `@servername` pravila). Ukoliko se logovi čuvaju isključivo lokalno, napadač nakon eskalacije privilegija može lako obrisati sve tragove svog prisustva.

- **Instalirani paketi:** Evidentiranje broja i tipa instaliranih paketa pomaže u identifikaciji i uklanjanju nepotrebnog softvera (kao što su alati za razvoj ili grafička okruženja na produkcionim serverima), čime se značajno sužava površina napada.